

Segregation of Duties (SoD)

Project Overview

This document will outline the process for the analysis of the conflict between Segregation of Duties (SoD) that has been simulated in this project.

This project aims to demonstrate how organizations can prevent conflicts in SAP systems to reduce the risk of fraud.

The project simulates the SAP GRC Access Control system, where business processes, role, and transactions are analyzed to detect access conflicts.

The analysis of business processes, roles, and responsibilities to detect access conflicts is typically done using SAP GRC Access Risk Analysis.

What is SoD?

Segregation of Duties is a security principle which ensures that an individual does not have too much control over critical business operations.

In enterprise systems like SAP, certain combinations of transactions can pose a risk if they are assigned to the same user.

For example:

- A user who can create a vendor
- Also execute vendor payments

This combination could be used by the user to pose as a vendor and pay money to the vendor.

In order to avoid this risk, the roles are divided between different people.

This ensures that one person does not complete an entire process without being monitored.

Why is SoD important?

Segregation of Duties is important in the maintenance of good internal controls and the prevention of fraud.

Organizations use Segregation of Duties to control:

- Preventing financial fraud
- Secure sensitive financial transactions
- Ensure accountability in business processes
- Maintain compliance with regulations such as SOX (Sarbanes-Oxley)

Thus, without proper segregation, the user may end up with the following unauthorized access rights:

- Create vendors
- Approve invoices
- Execute payments

This is a high-risk situation that may lead to financial fraud.

This, companies use Segregation of Duty controls offered by SAP GRC.

How conflicts are detected

SoD conflicts are identified by analyzing the relationship between:

- Business processes
- Transaction Codes
- Role assignment to users

The process for detecting SoD conflicts includes the following steps:

- Define business functions and related SAP transaction codes.
- Identify combinations of functions that lead to conflict.
- Create a conflict rule set (SoD Matrix)
- Evaluate user role assignments.

If a user has a set of roles with conflicting functions, the system will flag the user as having a SoD conflict.

In this project, conflicts are determined by:

- Role transaction permissions
- SoD conflict rules defined
- User role assignments

How conflicts are remediated

Once the conflict is identified, the organization must resolve or mitigate the risk. The common remediation techniques for role conflicts are:

- Removing one of the conflicting roles from the user.

Example: If a user has the following roles:

- Vendor creation role
- Payment processing role

The payment role may be removed.

Role redesign: Roles may be redesigned to remove risky transactions.

In some cases, these conflicts cannot be resolved due to business needs. In such cases, compensating controls are put in place.

Examples:

- Manager approval for payments
- Audit monitoring
- Transaction logging

These controls lower the risk associated with the conflict.

In SAP GRC, mitigation controls are documented, and their monitoring is done to ensure compliance.

Conclusion

This project presents a simplified simulation of the SAP GRC Segregation of Duties analysis process.

The analysis process identifies conflicts between critical business functions based on the permissions of the roles and the assignments of the users.

By resolving such conflicts, organizations can improve their internal controls and minimize the occurrence of fraud.

The approach used in this project is an illustration of the basic principles used in real SAP GRC Access Control implementations.